

Splunk Enterprise – Analisi e ricerca degli Indicatori di Compromissione su file tutorialdata.zip

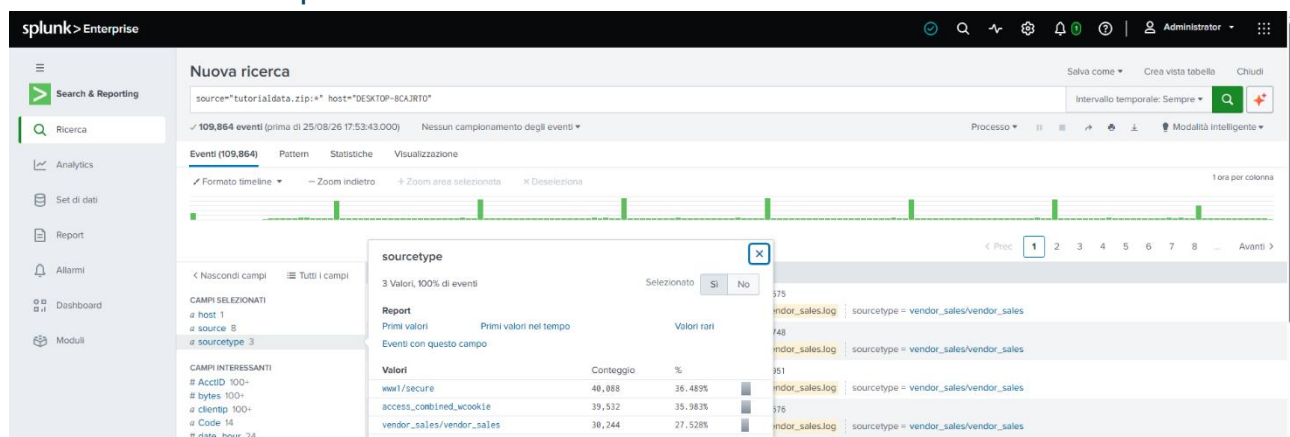
1. SINTESI ESECUTIVA

Obiettivo dell'Attività

L'indagine ha analizzato i **file di registro (log)** dell'infrastruttura web ed e-commerce aziendale contenuti nell'archivio **tutorialdata.zip**.

Attraverso la piattaforma **Splunk Enterprise**, è stato condotto un audit completo per **valutare la stabilità dei servizi web e rilevare eventuali minacce informatiche o comportamenti anomali**.

Risultati Principali e Conclusioni



1. Volume Dati Indicizzato: Sono stati esaminati **109,864 eventi totali**, suddivisi tra **traffico web, log di autenticazione e transazioni di vendita**.

2. Stato di Salute del Sito Web: L'**86,7%** delle interazioni degli utenti si conclude con successo (**200 OK**).

Tuttavia, emerge una quota critica di errori (**~13%**) legata sia a momenti di sovraccarico del server (**errori 503 e 500**), sia ad **attività automatizzate da parte di bot/scanners**.

3. Identificazione di una Minaccia: È stato isolato un indirizzo IP fortemente sospetto proveniente dal Regno Unito (**87.194.216.51**). Questo IP non solo genera il maggior numero di risposte di errore, ma **ha tentato attivamente di scovare e scaricare file riservati di sistema** (tra cui un file denominato **/passwords.pdf**).

2. DETTAGLIO TECNICO E METODOLOGICO PER FASI

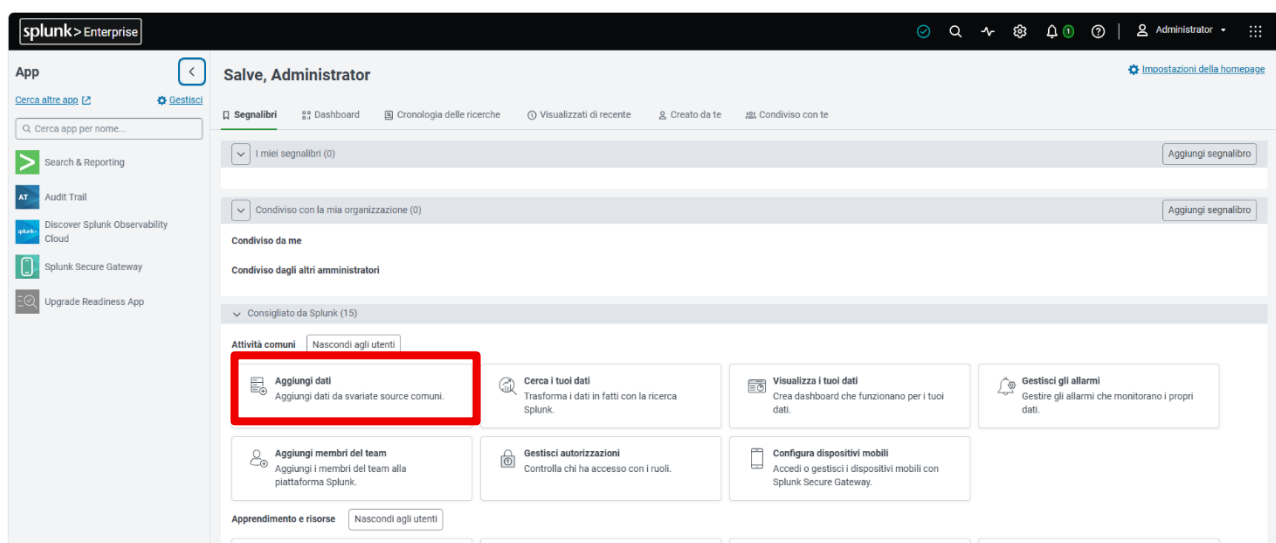
FASE 1: Procedura di Ingestion e importazione Dati (Add Data)

L'attività si è aperta con l'importazione dell'archivio log **tutorialdata.zip** all'interno dell'istanza **Splunk Enterprise** attraverso la procedura guidata.

A. Accesso al Menu "Aggiungi dati"

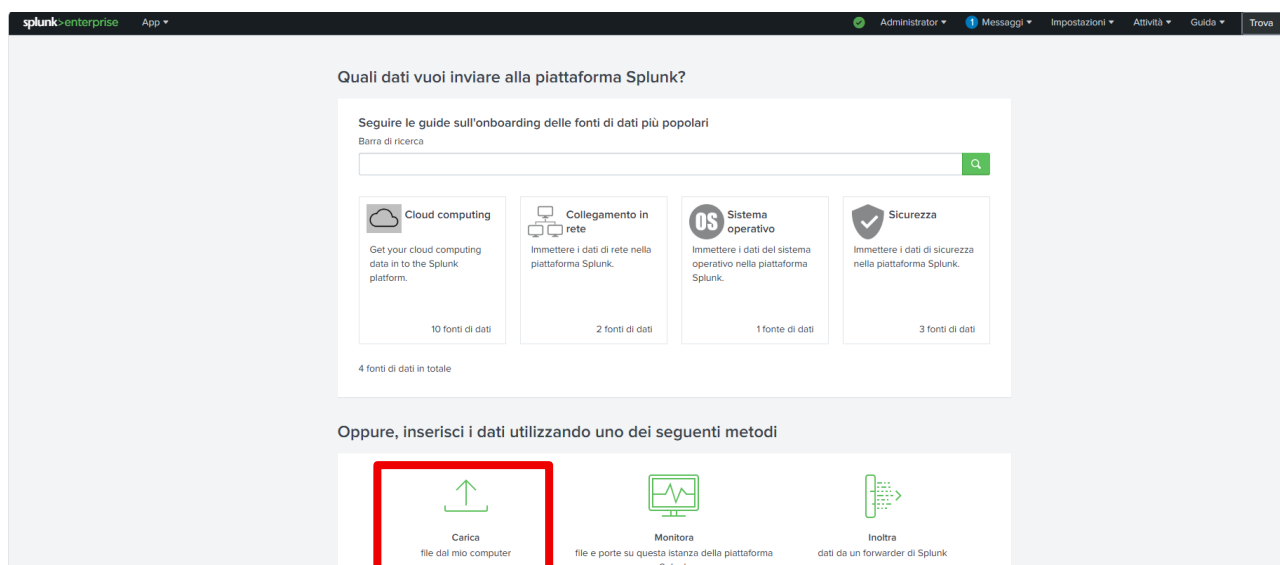
Dalla home page di Splunk Enterprise, si è acceduto alla sezione di inserimento selezionando il pulsante **Aggiungi dati** sotto *Attività comuni*.

- *Scelta operativa:* Trattandosi di un'analisi *forensic / retrospettiva* su un set di dati offline, l'upload diretto da interfaccia grafica rappresenta la scelta più snella ed efficace rispetto alla configurazione di un agente remoto (**Universal Forwarder**).



B. Selezione del Metodo di Input

Tra le modalità disponibili, è stata scelta l'opzione **Carica (file dal mio computer)** per eseguire l'upload dell'archivio locale.



C. Configurazione dei Parametri di Input

In fase di impostazione delle opzioni d'indicizzazione, sono stati definiti i seguenti parametri chiave:

- **Source type:** Impostato su Automatico. Questo consente a Splunk di riconoscere autonomamente le regole di parsing regex per i diversi formati (log web, log di sicurezza, log transazionali) ed estrarre in modo corretto i timestamp.
- **Host:** Configurato con il valore univoco DESKTOP-8CAJRTO per isolare il dataset da altre possibili fonti dell'istanza.
- **Indice:** Assegnato all'indice predefinito Default (main).

Impostazioni di input

In alternativa, impostare ulteriori parametri di input per questo input di dati come segue:

Source type

Il source type è uno dei campi di default che la piattaforma Splunk assegna a tutti i dati in entrata. Indica alla piattaforma Splunk il tipo di dati che si hanno, in modo che la piattaforma Splunk possa formattarli in modo intelligente durante l'indicizzazione. Rappresenta anche un modo per suddividere i dati in categorie in modo da semplificare le ricerche tra i dati.

Host

Quando la piattaforma Splunk indicizza i dati, ciascun evento riceve un valore "host". Il valore host deve essere il nome della macchina da cui ha origine l'evento. Il tipo di input scelto determina le opzioni di configurazione disponibili. [Ulteriori informazioni](#)

Indice

La piattaforma Splunk archivia i dati in entrata come eventi nell'indice selezionato. Valutare l'uso di un indice "sandbox" come destinazione se si hanno problemi a determinare un source type per i propri dati. Un indice sandbox consente di risolvere i problemi a livello di configurazione senza conseguenze negative sugli indici di produzione. È sempre

D. Verifica e Conferma

È stato convalidato il riepilogo delle impostazioni prima di procedere all'indicizzazione vera e propria.

E. Completamento dell'Importazione

L'operazione è terminata con successo, rendendo l'intero archivio immediatamente disponibile per l'analisi.

File è stato caricato correttamente.

Configurare gli input da Impostazioni > Input dati

Avvia ricerca Esegui una ricerca tra i dati ora oppure visualizzare [esempi ed esercitazioni](#).

Aggiungi altri dati Aggiungere altri input di dati ora oppure visualizzare [esempi ed esercitazioni](#).

Scarica app Le app consentono di fare di più con i propri dati. [Ulteriori informazioni](#).

Crea dashboard Visualizza le ricerche. [Ulteriori informazioni](#).

FASE 2: Categorizzazione delle Sorgenti e Parsing dei Dati

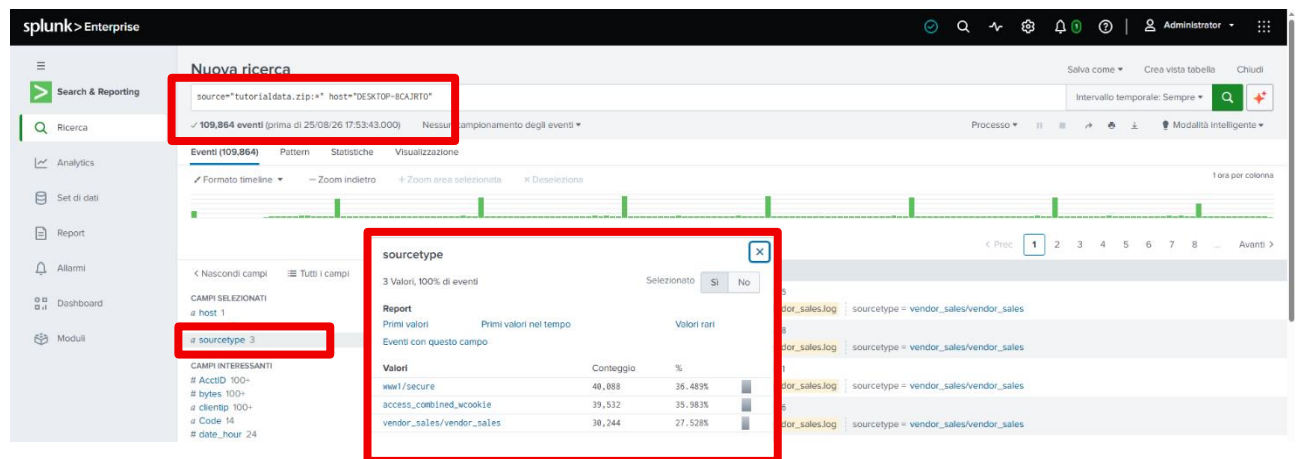
Attraverso la ricerca globale:

`source="tutorialdata.zip:*" host="DESKTOP-8CAJRTO"`

Splunk ha restituito **109,864 eventi complessivi**.

Dall'analisi del campo sourcetype, il volume è risultato distribuito tra 3 tipologie principali di log:

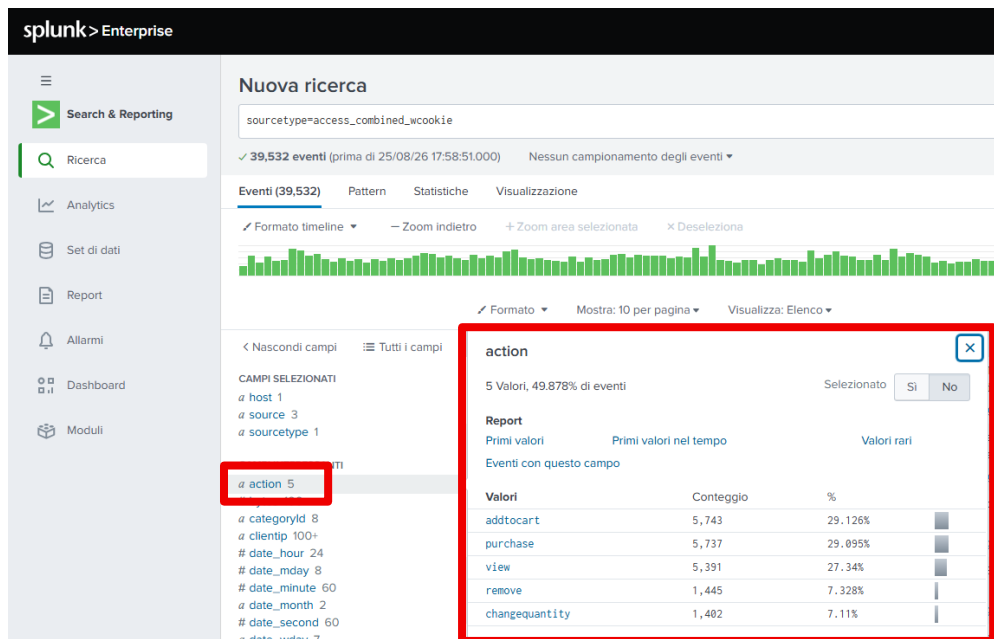
- **www1/secure**: Log di sicurezza e autenticazioni (**40.088 eventi / 36,49%**)
- **access_combined_wcookie**: Log di traffico del web server HTTP/HTTPS (**39.532 eventi / 35,98%**)
- **vendor_sales/vendor_sales**: Log transazionali e vendite (**30.244 eventi / 27,53%**)



Estrazione dei Campi Applicativi (action)

Filtrando per i soli log web (**sourcetype=access_combined_wcookie**), è stato ispezionato il campo **action** per mappare i comportamenti d'uso sul portale e-commerce:

- **addtocart**: 5.743 eventi (29,13%) — **Inserimento prodotti nel carrello.**
- **purchase**: 5.737 eventi (29,10%) — **Transazioni completate.**
- **view**: 5.391 eventi (27,34%) — **Consultazione catalogo.**
- **remove**: 1.445 eventi (7,33%) — **Rimozione dal carrello.**
- **changequantity**: 1.402 eventi (7,11%) — **Modifica delle quantità ordini.**

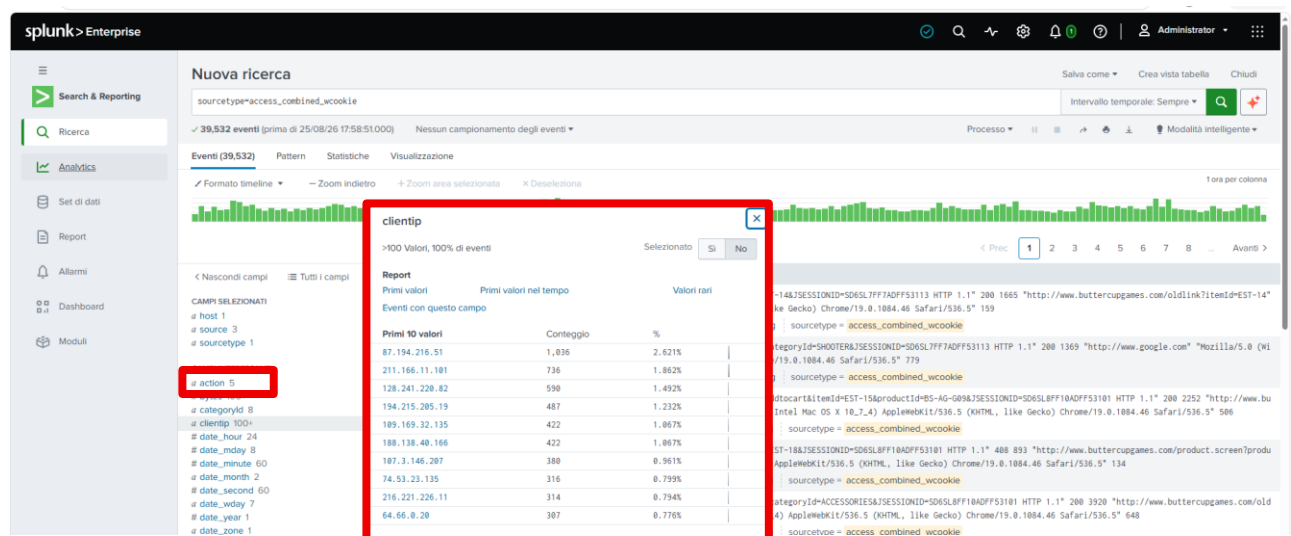


FASE 3: Analisi del Traffico Web e Diagnostica di Rete (access_combined_wcookie)

A. Identificazione degli IP Client Più Attivi (clientip)

La profilazione del campo **clientip** evidenzia la presenza di un primario "Top Talker" che si stacca notevolmente dalla media del traffico generato dagli altri utenti:

- **87.194.216.51**: 1.036 eventi (2,62%) — **Principale IP Sospetto / Top Talker**
- **211.166.11.101**: 736 eventi (1,86%)
- **128.241.220.82**: 590 eventi (1,51%)
- **194.215.205.19**: 487 eventi (1,23%)
- **109.169.32.135**: 422 eventi (1,07%)



B. Distribuzione dei Codici di Stato HTTP (status)

L'analisi delle risposte restituite dal web server fornisce un quadro chiaro sia della salute del sistema, sia dei problemi presenti:

Codice Status	Conteggio Eventi	Percentuale	Tipologia e Descrizione Tecnico-Funzionale
200	34.282	86,72%	OK: Richieste elaborate con successo.
503	952	2,41%	Service Unavailable: Server o backend momentaneamente saturo.
408	756	1,91%	Request Timeout: Richiesta scaduta prima del completamento.
500	733	1,85%	Internal Server Error: Errore interno dell'applicazione web.
406	710	1,80%	Not Acceptable: Intestazioni della richiesta rifiutate.
400	701	1,77%	Bad Request: Sintassi della richiesta client non corretta.
404	690	1,75%	Not Found: Risorsa inesistente (indicatore di scanning).
505	480	1,21%	HTTP Version Not Supported: Protocollo HTTP non supportato.
403	228	0,58%	Forbidden: Tentativo di accesso a risorsa protetta.

The screenshot shows a Splunk search interface. The search bar at the top contains the query: `search%20sourcetype%3Daccess_combined_wcookie&earliest=0&latest=&display.page.search.mode=smart&dispatch.sample_ratio=1&workload_pool=&sid=1787673530.12`. The sidebar on the left lists various fields, with `# status 9` highlighted in a red box. The main results pane displays a table of search results. A red box highlights a specific result, which is a table showing the distribution of status codes. The table has columns for 'Valori', 'Conteggio', and '%'. The data is as follows:

Valori	Conteggio	%
200	34,282	86.72%
503	952	2.408%
408	756	1.912%
500	733	1.854%
405	718	1.796%
400	701	1.773%
404	690	1.745%
505	480	1.214%
403	228	0.577%

C. Mappatura degli Endpoint Sollecitati (uri_path)

La distribuzione delle risorse web richieste mostra il normale flusso di navigazione ma segnala la presenza di percorsi critici:

- **/cart.do**: 12.653 eventi (32,01%)
- **/product.screen**: 9.932 eventi (25,12%)
- **/category.screen**: 6.885 eventi (17,42%)
- **/oldlink**: 6.871 eventi (17,38%)
- **/cart/success.do**: 2.154 eventi (5,45%)
- **/cart/error.do**: 427 eventi (1,1%)
- **/hidden/anna_nicole.html**: 73 eventi (0,19%) — *Anomalia: risorsa nascosta sollecitata.*

Dal punto di vista della Threat Intelligence, il file **/hidden/anna_nicole.html** rappresenta un noto **Easter Egg** inserito nei dataset di test di Splunk.

Tuttavia, la sua presenza nei file di log e le relative richieste ricevute confermano l'efficacia dell'indagine: dimostrano che gli attori malevoli (botnet e scanner remoti) stanno utilizzando dizionari di **wordlisting/fuzzing** automatizzati per perlustrare cartelle nascoste e directory di sistema non indicizzate nel menu principale del sito web.

```

a itemid 14
a JSESSIONID 100+
# linecount 1
a method 2
# other 100+
a productid 16
a punct 98
a referer 100+
a referer_domain 4
a req_time 100+
a splunk_server 1
# status 9
# timeendpos 7
# timestartpos 7
a uri 100+
a uri_path 14
a uri_query 100+
a user 1
a useragent 26
# version 1

4 campi in più
+ Estrai nuovi campi

```

uri_path

14 Valori, 100% di eventi

Selezionato

Report

Primi valori

Primi valori nel tempo

Valori rari

Eventi con questo campo

Primi 10 valori	Conteggio	%
/cart.do	12,653	32.007%
/product.screen	9,932	25.124%
/category.screen	6,885	17.416%
/oldlink	6,871	17.381%
/cart/success.do	2,154	5.449%
/cart/error.do	427	1.08%
show.do	90	0.228%
/stuff/logo.ico	84	0.212%
/productscreen.html	82	0.207%
/hidden/anna_nicole.html	73	0.185%

```

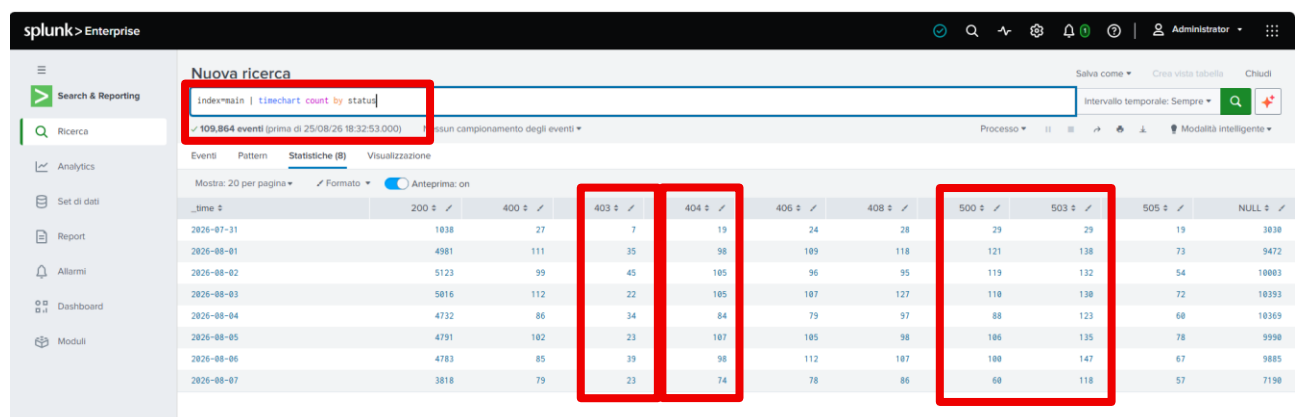
sourcetype = access,
purchase&itemId=EST-6&J
-AG-G07" "Mozilla/5.0
sourcetype = access,
categoryId=SHOOTER&JSES
5 X 10_7_4) AppleWebKi
sourcetype = access,
dtocart&itemId=EST-12&
(Macintosh; Intel Mac
sourcetype = access,
dtocart&itemId=EST-6&
(Macintosh; Intel Mac
sourcetype = access,

```

FASE 4: Threat Hunting, Geolocalizzazione e Profilazione dell'Attaccante

A. Timeline e Correlazione Temporale (timechart)

Attraverso la query ***index=main | timechart count by status***, è stato monitorato l'andamento del traffico nel tempo. La presenza costante di **errori 503** e **500** associata a un flusso continuo di codici, **404** dimostra che **il web server soffre sia di picchi di carico prestazionale, sia di un'attività automatizzata di scansione incessante**.



B. Geolocalizzazione degli Errori 404 (iplocation)

Eseguendo la query ***index=* status=404 | iplocation clientip | stats count by clientip, Country | sort - count*** per la geolocalizzazione degli IP, è stata ricostruita la classifica degli IP che generano più errori di "Pagina Non Trovata" (tipico segnale di *fuzzing* e *vulnerability scanning*):

Client IP	Paese di Origine	Errori 404 Generati	Valutazione della Minaccia
87.194.216.51	United Kingdom	28	Attaccante Principale (Top Offender)

Client IP	Paese di Origine	Errori 404 Generati	Valutazione della Minaccia
211.166.11.101	China	15	Botnet / Scansione automatizzata
128.241.220.82	United States	13	Botnet / Scansione automatizzata
88.12.32.208	Spain	10	Scanner web / Crawler
124.160.192.241	China	9	Scanner automatizzato
175.44.1.172	China	9	Scanner automatizzato
91.205.189.15	Russia	9	Scanner automatizzato

The screenshot shows the Splunk Enterprise search interface. The search bar contains the query: `index=* status=404 | iplocation clientip | stats count by clientip, Country | sort - count`. The results are displayed in a table with columns: clientip, Country, and count. The results are sorted by count in descending order.

clientip	Country	count
87.194.216.51	United Kingdom	20
211.166.11.101	China	15
128.241.220.82	United States	13
88.12.32.208	Spain	10
124.160.192.241	China	9
175.44.1.172	China	9
91.205.189.15	Russia	9
109.169.32.135	United Kingdom	8
117.21.246.164	China	8
148.107.2.20	United States	8
188.138.40.166	Germany	8
216.221.226.11	United States	8
111.161.27.20	China	7
118.142.68.222	Hong Kong	7
123.118.73.155	China	7
174.123.217.162	United States	7
175.44.1.122	China	7
194.215.285.19	Finland	7
27.102.11.11	South Korea	7
74.53.23.135	United States	7

C. Identificazione della Tecnica di Attacco (Deep-Dive IP 87.194.216.51)

Isolando le richieste effettuate dall'**IP 87.194.216.51**, è emerso un pattern chiaro di **Directory Traversal / Sensitive Data Hunting**:

- **/passwords.pdf**: Tentativo diretto di scaricare file di credenziali non protetti.
- **/rush/signals.zip**: Tentativo di recuperare archivi di dati o file di backup.
- **/hidden/anna_nicole.html**: Fuzzing su risorse nascoste.
- **/numa/numa.html**: Scansione di percorsi non standard.

splunk> Enterprise

Nuova ricerca

`index=* status=484 clientip="87.194.216.51" | iplocation clientip`

✓ 20 eventi (prima di 25/08/26 18:55:53.000) Nessun campionamento degli eventi

Processo | Modaltà intelligente

Formato timeline | Zoom indietro | Zoom area selezionata | Deselezione | 1 giorno per colonna

Formato | Mostra: 10 per pagina | Visualizza: Elenco

Eventi (20)

Ora	Evento
07/08/26 06:49:32.000	87.194.216.51 - - [07/Aug/2026:06:49:32] "POST /numa/numa.html?SESSIONID=S05SL8FF3ADFF58038 HTTP 1.1" 404 2686 "http://www.buttercupgames.com/category.screen?categoryId=NALL" Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:1.9.2.28) Gecko/20120306 Firefox/3.6.28 (.NET CLR 3.5.30729; .NET4.0C) 478 host = DESKTOP-8CAJRT0 source = tutorialdata.zip/wwwl/access.log sourcetype = access_combined_wcookie
06/08/26 18:21:45.000	87.194.216.51 - - [06/Aug/2026:18:21:45] "GET /search.do?items=211287SESSIONID=S02SL1FF18ADFF46115 HTTP 1.1" 404 1585 "http://www.buttercupgames.com/cart.do?action=view&itemId=EST-16" Mozilla/5.0 (Windows; U; Windows NT 5.1; en-US; rv:1.9.2.28) Gecko/20120306 Firefox/3.6.28 (.NET CLR 3.5.30729; .NET4.0C) 920 host = DESKTOP-8CAJRT0 source = tutorialdata.zip/wwwl/access.log sourcetype = access_combined_wcookie
06/08/26 17:52:09.000	87.194.216.51 - - [06/Aug/2026:17:52:09] "GET /productscreen.html?ou81287SESSIONID=S02SL3FF1ADFF48018 HTTP 1.1" 404 2391 "http://www.buttercupgames.com/product.screen?productId=SF-BV5-G01" Opera/9.20 (Windows NT 6.0; U; en) 575 host = DESKTOP-8CAJRT0 source = tutorialdata.zip/wwwl/access.log sourcetype = access_combined_wcookie
06/08/26 10:30:39.000	87.194.216.51 - - [06/Aug/2026:10:30:39] "GET show.do?productId=SF-BV5-81AJSESSIONID=S02SL7FF18ADFF43983 HTTP 1.1" 404 1870 "http://www.buttercupgames.com/cart.do?action=view&itemId=EST-12" Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; WOW64; Trident/5.0; BOIEE;ENUS) 908 host = DESKTOP-8CAJRT0 source = tutorialdata.zip/wwwl/access.log sourcetype = access_combined_wcookie
06/08/26 00:11:08.000	87.194.216.51 - - [06/Aug/2026:00:11:08] "GET /hidden/anna_nicole.html?SESSIONID=S04SL6FF7ADFF40941 HTTP 1.1" 404 2262 "http://www.buttercupgames.com/oldlink?itemId=EST-19" Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 5.1; .NET CLR 2.0.50727; .NET CLR 3.0.4506.2152; .NET CLR 3.5.30729; InfoPath.1; .NET4.0C; .NET4.0E; MS-RM LH 8) 612 host = DESKTOP-8CAJRT0 source = tutorialdata.zip/wwwl/access.log sourcetype = access_combined_wcookie

uri_path

9 Valori, 100% di eventi

Report	Primi valori	Primi valori nel tempo	Valori rari
uri_path	/passwords.pdf	3	15%
	/product.screen	3	15%
	/productscreen.html	3	15%
	/search.do	3	15%
	/stuff/logo.ico	3	15%
	/rush/signals.zip	2	10%
	/hidden/anna_nicole.html	1	5%
	/numa/numa.html	1	5%
	show.do	1	5%

D. Profilazione delle Transazioni dell'Attaccante

Incrociando l'attività dell'IP sospetto con le transazioni e-commerce mediante la query **`index=* clientip="87.194.216.51" action=purchase | stats count by status, uri_path`**

Sono stati rilevati **151 eventi complessivi**:

- 55 acquisti sono andati a buon fine (**status=200 su /cart/success.do**).
- L'IP ha inoltre generato 7 errori **503 (Service Unavailable)** e 3 errori **400 (Bad Request)** sul carrello.

Analisi del Comportamento: L'IP fa uso di uno script automatico pianificato sia per eseguire operazioni massive di **Carding / Fraud Automation** (acquisti automatici), sia per condurre la scansione e l'estrazione di file critici dal server web.

splunk> Enterprise

Nuova ricerca

`index=* clientip="87.194.216.51" action=purchase | stats count by status, uri_path`

✓ 151 eventi (prima di 25/08/26 19:10:19.000) Nessun campionamento degli eventi

Processo | Modaltà intelligente

Mostra: 20 per pagina | Formato | Anteprima: on

status	uri_path	count
200	/cart.do	67
200	/cart/error.do	12
200	/cart/success.do	55
400	/cart.do	3
400	/product.screen	1
400	/cart.do	2
503	/cart.do	7
503	/cart.do	2
503	/category.screen	2

3. Matrice dei Rischi e Raccomandazioni Strategiche

Rischio Rilevato	Sorgente / Attore	Impatto Aziendale	Azione Correttiva Suggerita
Tentativo di Esfiltrazione Dati Sensibili	IP 87.194.216.51 (UK)	Alto: Tentativi di accesso a file credenziali (/passwords.pdf),	Blocklist Immediata: Inserire l'IP nel Firewall/WAF e bonificare le directory web da file riservati.
Acquisti Automatizzati / Frode	IP 87.194.216.51 (UK)	Medio-Alto: 55 acquisti completati con successo tramite script/bot automatizzato su un totale di 151 transazioni sollecitate.	Integrazione CAPTCHA: Rate Limiting sulle chiamate POST verso /cart.do e blocco delle sessioni non umane.
Scansione e Fuzzing Indiscriminato	IP da Cina, Russia, USA	Medio: Consumo di banda e generazione continuativa di errori 404.	Rate Limiting & Geo-IP Block: Limitare il numero massimo di richieste per minuto per singolo IP.
Instabilità e Degrado del Server	Cause Interne (Errori 503/500)	Medio: Oltre il 4% delle richieste fallisce per errore del server.	Ottimizzazione delle Risorse: Incrementare la capacità hardware/cloud e ottimizzare le query sul database del carrello.